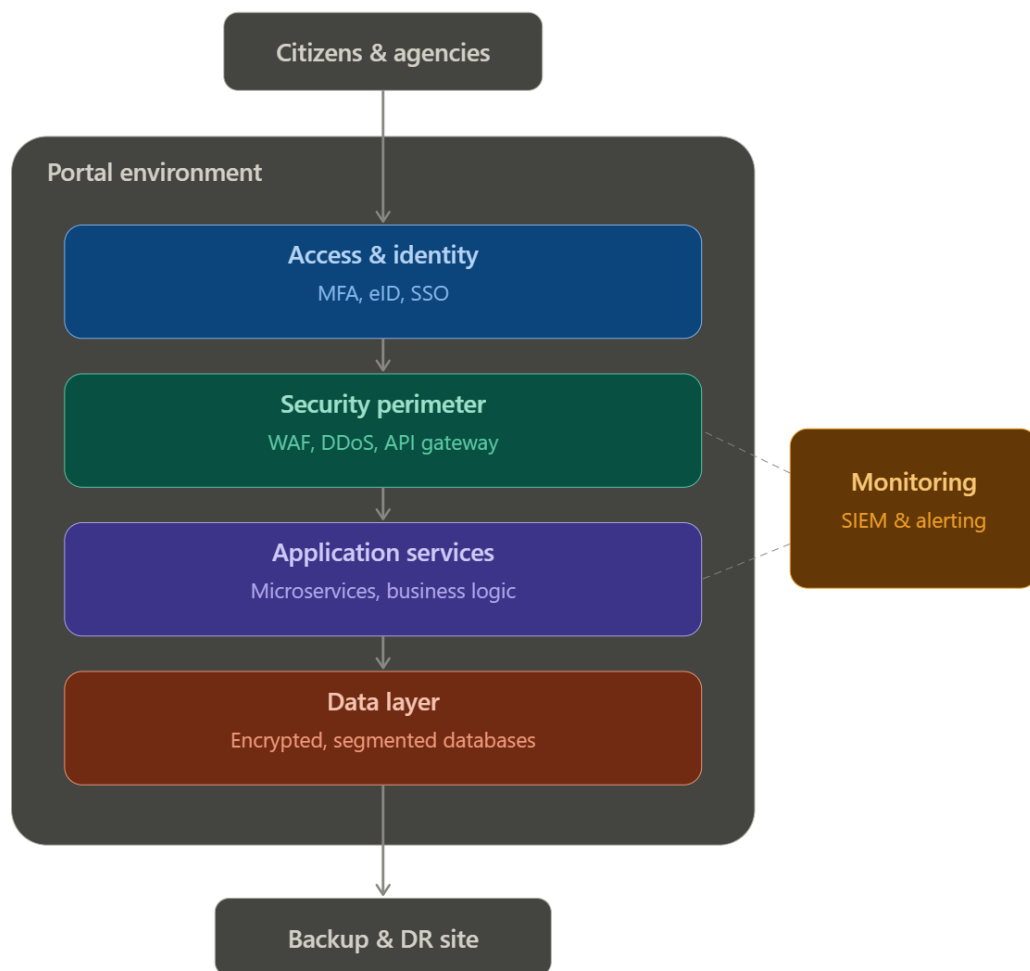


Government citizen-service portals sit at a hard intersection: they must be reachable by the public 24/7, yet they hold some of the most sensitive data that exists — tax records, health data, benefits, identity documents — and they're a high-value target for both criminals and state actors. The design below treats "secure" as a property of the whole system, not a bolt-on control. Here's how each layer breaks down in practice.



Access & identity

- Strong citizen authentication via national eID, FIDO2/WebAuthn, or mobile-based digital identity, with MFA mandatory for anything touching personal data.
- Role- and attribute-based access control (RBAC/ABAC) for internal agency staff, with least-privilege defaults and just-in-time elevation for sensitive operations.
- Federated identity (SAML/OIDC) so citizens use one credential across services instead of re-registering per agency.
- Session management with short-lived tokens, device binding, and anomaly-based step-up authentication (impossible travel, new device, etc.).

Security perimeter

- Web application firewall (WAF) and bot management in front of every public endpoint.
- DDoS protection at the network edge (scrubbing centers, anycast, rate limiting) — critical for services citizens rely on during emergencies (benefits, disaster relief).
- API gateway enforcing schema validation, rate limits, and mutual TLS for service-to-service and third-party integrations.
- TLS 1.3 everywhere; no plaintext internal traffic even inside the perimeter (zero trust — verify every request regardless of network location).

Application services

- Microservices with clear trust boundaries, each with its own minimal permissions — a form-submission service shouldn't have direct access to the identity database.
- Secure SDLC: static/dynamic analysis, dependency scanning, and mandatory code review gates before deployment; secrets never hardcoded, pulled from a managed vault (HSM-backed).
- Immutable infrastructure and signed container images so a compromised build can't silently persist.

Data layer

- Encryption at rest (AES-256) and in transit, with keys managed in an HSM or cloud KMS, separate from the data itself.
- Data segmentation by sensitivity tier — e.g., public records, PII, and health/financial data live in separately access-controlled stores, not one shared database.
- Data minimization and retention limits: collect only what's needed, purge on schedule, and tokenize/pseudonymize identifiers where full values aren't required downstream.
- Field-level access logging so every read of sensitive data is attributable to a specific authenticated request.

Monitoring & backup (wrapping the whole stack)

- Centralized logging and a SIEM correlating identity, network, and application events, with 24/7 SOC coverage and defined incident-response playbooks (breach notification timelines matter for government services under most legal frameworks).
- Immutable, geographically separated backups and a tested disaster-recovery plan with defined RTO/RPO — citizen services can't have unbounded downtime.
- Continuous compliance monitoring against relevant frameworks (e.g., NIST 800-53, FedRAMP, ISO 27001, or the equivalent national standard) plus regular third-party penetration testing and red-team exercises.

Governance considerations that often get missed

- **Supply chain:** vetting and continuously monitoring third-party vendors and open-source dependencies — a common breach vector for public-sector systems.
- **Accessibility and availability:** security controls (CAPTCHAs, MFA) shouldn't lock out citizens without smartphones or with disabilities — offer alternate verification paths.
- **Auditability:** every privileged action by an agency employee should be logged and reviewable, both for security and public accountability.
- **Incident transparency:** a public breach-disclosure process, since trust in government digital services is fragile and slow to rebuild.